

SOC 2 Compliance Report

Trust Service Criteria Assessment

Generated: March 15, 2026 at 3:44 PM PDT

Powered by Reflex ^{â€} Kubernetes Blast Radius Intelligence

Cluster Information

Cluster:	kind-yikes-demo
Namespace:	acme-prod
Pods Scanned:	10
NetworkPolicies:	3
Cluster Risk Score:	69/100
Scan Time:	2026-03-15T15:44:52-07:00

Compliance Summary

63%

NEEDS ATTENTION

20 controls assessed | 8 passing | 12 require action

Control	Name	Status	Score	Violations	Findings
CC3.1	Risk Identification and Assessment	FAIL	30/100	8	8
CC3.2	Risk Assessment of Changes	PASS	100/100	0	0
CC3.4	Risk from Fraud and Unauthorized Activity	PARTIAL	90/100	1	6
CC4.1	Monitoring of Controls	PASS	100/100	0	0
CC5.2	Technology General Controls	FAIL	20/100	8	1
CC6.1	Logical and Physical Access Controls	FAIL	30/100	7	7
CC6.2	System User Access Provisioning	PASS	100/100	0	1
CC6.3	Role-Based Access and Least Privilege	FAIL	28/100	9	9
CC6.5	Restriction of System Access	PASS	100/100	0	0
CC6.6	Network Security and Segmentation	FAIL	16/100	7	14
CC6.7	Restriction of Data Movement	PASS	100/100	0	0
CC6.8	Prevention of Unauthorized Software	PARTIAL	50/100	8	2
CC7.1	Detection of Unauthorized Activities	PASS	100/100	0	0
CC7.2	Monitoring Security Events	PASS	100/100	0	0
CC7.3	Evaluation of Security Events	PASS	100/100	0	0
CC7.4	Incident Response	PARTIAL	70/100	0	0
CC8.1	Change Management and Vulnerability Remediation	FAIL	0/100	1042	10
CC9.1	Risk Mitigation	PARTIAL	50/100	0	0
C1.1	Confidential Information Protection	FAIL	0/100	5	5

A1.1	System Availability and Recovery	PARTIAL	80/100	0	0
------	----------------------------------	---------	--------	---	---

RBAC Audit Summary

10 pods audited | 0 critical RBAC risk | 0 high RBAC risk

CC3.1 “ Risk Identification and Assessment

Status: **FAIL** Score: 30/100 Violations: 8

Evidence

- Blast radius scoring active on 10 pods. 7 critical, 1 high.
- Reflex composite scoring active across 10 pods
- Critical-tier pods: search-service, analytics-engine, notification-service, cart-service, api-gateway (+2 more)
- High-tier pods: auth-service
- Risk assessment runs every scan cycle with historical trending

Findings (8)

- CRITICAL: search-service is critical-tier risk
- CRITICAL: analytics-engine is critical-tier risk
- CRITICAL: notification-service is critical-tier risk
- CRITICAL: cart-service is critical-tier risk
- CRITICAL: api-gateway is critical-tier risk
- CRITICAL: order-service is critical-tier risk
- CRITICAL: user-service is critical-tier risk
- HIGH: auth-service is high-tier risk

Remediation

Remediate critical-tier pods first by adding NetworkPolicies, patching CVEs, and restricting permissions. Target: zero critical-tier pods.

CC3.2 “ Risk Assessment of Changes

Status: PASS Score: 100/100 Violations: 0

Evidence

Drift detection compares consecutive scans. Evidence vault maintains hash-chained records for 10 pods.

- Drift detector runs after each scan comparing control statuses
- SHA-256 hash-chained evidence vault prevents tampering
- Score deltas tracked per pod and per control

Remediation

No action needed. Drift detection is active.

CC3.4 – Risk from Fraud and Unauthorized Activity

Status: **PARTIAL** Score: 90/100 Violations: 1

Evidence

Privileged pods: 1. Cluster-admin pods: 0. Pods with privilege escalation: 5.

- Privileged containers: search-service
- Cluster-admin ServiceAccounts: none
- Privilege escalation allowed: search-service, analytics-engine, notification-service, api-gateway, auth-service

Findings (6)

- HIGH: search-service runs in privileged mode
- MEDIUM: search-service allows privilege escalation
- MEDIUM: analytics-engine allows privilege escalation
- MEDIUM: notification-service allows privilege escalation
- MEDIUM: api-gateway allows privilege escalation
- MEDIUM: auth-service allows privilege escalation

Remediation

Remove privileged mode, eliminate cluster-admin bindings, disable allowPrivilegeEscalation on all pods.

CC4.1 " Monitoring of Controls

Status: PASS Score: 100/100 Violations: 0

Evidence

Continuous monitoring active. 10 pods scanned per cycle. Prometheus metrics on :9090.

- Automated scanning of 10 pods per cycle
- Prometheus metrics exported for alerting integration
- Alert rules: critical-cve-high-blast, cluster-score-increase, netpol-removed
- Evidence vault records every scan for audit trail

Remediation

No action needed. Monitoring is active.

CC5.2 " Technology General Controls

Status: **FAIL** Score: 20/100 Violations: 8

Evidence

Read-only root filesystem: 2 of 10 pods. 10 unique images scanned.

- Read-only root filesystem enforced on 2/10 pods
- 10 unique container images scanned for vulnerabilities
- NetworkPolicies deployed

Findings (1)

8 pods lack read-only root filesystem

Remediation

Enable readOnlyRootFilesystem on all containers. Use minimal base images.

CC6.1 “ Logical and Physical Access Controls

Status: **FAIL** Score: 30/100 Violations: 7

Evidence

7 of 10 pods lack NetworkPolicy. 3 NetworkPolicies deployed.

- NetworkPolicy coverage: 3/10 pods (30%)
- Unprotected pods: search-service, analytics-engine, notification-service, cart-service, api-gateway (+2 more)
- Total NetworkPolicies: 3

Findings (7)

- FAIL: search-service has no NetworkPolicy
- FAIL: analytics-engine has no NetworkPolicy
- FAIL: notification-service has no NetworkPolicy
- FAIL: cart-service has no NetworkPolicy
- FAIL: api-gateway has no NetworkPolicy
- FAIL: order-service has no NetworkPolicy
- FAIL: user-service has no NetworkPolicy

Remediation

Apply NetworkPolicies to all unprotected pods. Run: `reflex generate netpol --namespace <ns>`

CC6.2 " System User Access Provisioning

Status: PASS Score: 100/100 Violations: 0

Evidence

ServiceAccounts: default. Cluster-admin: 0. Wildcard access: 0. Default SA: 10 pods.

- Unique ServiceAccounts: default
- Pods with cluster-admin: none
- Pods with wildcard access: none
- Pods using default ServiceAccount: 10

Findings (1)

INFO: 10 pods using default ServiceAccount

Remediation

Create dedicated ServiceAccounts per workload. Remove cluster-admin bindings. Apply least-privilege RBAC policies.

CC6.3 " Role-Based Access and Least Privilege

Status: **FAIL** Score: 28/100 Violations: 9

Evidence

Privileged: 1. Root: 3. Escalation: 5. Exec access: 0. Secret access: 0.

- ⌘Privileged containers: search-service
- ⌘Root containers: search-service, analytics-engine, auth-service
- ⌘Privilege escalation: search-service, analytics-engine, notification-service, api-gateway, auth-service
- ⌘Pods with exec capability: none
- ⌘Pods with secret access: none

Findings (9)

- CRITICAL: search-service runs privileged
- HIGH: search-service runs as root
- HIGH: analytics-engine runs as root
- HIGH: auth-service runs as root
- MEDIUM: search-service allows privilege escalation
- MEDIUM: analytics-engine allows privilege escalation
- MEDIUM: notification-service allows privilege escalation
- MEDIUM: api-gateway allows privilege escalation
- MEDIUM: auth-service allows privilege escalation

Remediation

Remove privileged mode. Set runAsNonRoot: true. Disable allowPrivilegeEscalation. Restrict RBAC to minimum required verbs/resources.

CC6.5 “ Restriction of System Access

Status: PASS Score: 100/100 Violations: 0

Evidence

Pods with escalate/bind/impersonate: 0. Namespace isolation via RBAC.

- “Pods with escalation privileges: none
- “Namespace-scoped RBAC in place for 10 pods

Remediation

Remove escalate, bind, and impersonate verbs from all workload ServiceAccounts.

CC6.6 " Network Security and Segmentation

Status: **FAIL** Score: 16/100 Violations: 7

Evidence

Internet-exposed: 7. Unrestricted egress: 7. Data store access: 0.

- Internet-exposed pods: search-service, analytics-engine, notification-service, cart-service, api-gateway (+2 more)
- Unrestricted egress: search-service, analytics-engine, notification-service, cart-service, api-gateway (+2 more)
- Pods with data store access: 0
- NetworkPolicies deployed: 3

Findings (14)

- HIGH: search-service has internet access without NetworkPolicy
- HIGH: analytics-engine has internet access without NetworkPolicy
- HIGH: notification-service has internet access without NetworkPolicy
- HIGH: cart-service has internet access without NetworkPolicy
- HIGH: api-gateway has internet access without NetworkPolicy
- HIGH: order-service has internet access without NetworkPolicy
- HIGH: user-service has internet access without NetworkPolicy
- MEDIUM: search-service has unrestricted egress
- MEDIUM: analytics-engine has unrestricted egress
- MEDIUM: notification-service has unrestricted egress
- MEDIUM: cart-service has unrestricted egress
- MEDIUM: api-gateway has unrestricted egress
- MEDIUM: order-service has unrestricted egress
- MEDIUM: user-service has unrestricted egress

Remediation

Apply egress NetworkPolicies to restrict internet access. Segment data store access with targeted policies.

CC6.7 – Restriction of Data Movement

Status: PASS Score: 100/100 Violations: 0

Evidence

0 pods access data stores. 0 of those lack NetworkPolicy.

- Data store pods: none
- Unprotected data store pods: 0

Remediation

Apply NetworkPolicies to all pods with data store access. Restrict egress to specific database endpoints.

CC6.8 " Prevention of Unauthorized Software

Status: **PARTIAL** Score: 50/100 Violations: 8

Evidence

- 10 unique images scanned. Read-only root FS: 2/10 pods.
- ✓ Vulnerability scanning via Trivy: 10 images
- ✓ Read-only root filesystem: 2/10 pods
- ✗ Image provenance not fully verified (no admission controller detected)

Findings (2)

- MEDIUM: 8 pods lack read-only root filesystem " writable FS enables malware persistence
- INFO: No admission controller detected " image provenance not enforced

Remediation

Enable readOnlyRootFilesystem on all pods. Deploy an admission controller (e.g., Kyverno, OPA Gatekeeper) to enforce trusted image registries.

CC7.1 – Detection of Unauthorized Activities

Status: **PASS** Score: 100/100 Violations: 0

Evidence

Continuous monitoring: 10 pods. Prometheus metrics on :9090.

- Reflex continuous scanning active on 10 pods
- Prometheus metrics exported for Grafana/AlertManager integration
- Alert rules: critical CVEs, score regressions, NetworkPolicy changes
- Evidence vault with hash chain for tamper detection

Remediation

No action needed. Monitoring is active.

CC7.2 “ Monitoring Security Events

Status: PASS Score: 100/100 Violations: 0

Evidence

Alert engine active. Drift detection across 10 pods. Hash-chained evidence vault.

- Alert engine with configurable rules and thresholds
- Drift detection compares consecutive scans for regressions
- Evidence vault maintains immutable record chain for 10 pods

Remediation

No action needed. Security event monitoring is active.

CC7.3 Evaluation of Security Events

Status: PASS Score: 100/100 Violations: 0

Evidence

Composite scoring: CVE + blast radius + permissions + policy gap. Avg blast: 7.6. Max blast: 10.

• Composite risk scoring: CVE severity — blast radius — permissions — policy gaps

• Average blast radius: 7.6 reachable targets

• Maximum blast radius: 10 targets

• Per-pod risk tiers: critical (≥75), high (≥50), medium (≥25), low (<25)

Remediation

No action needed. Risk evaluation is automated.

CC7.4 " Incident Response

Status: **PARTIAL** Score: 70/100 Violations: 0

Evidence

Automated remediation recommendations generated per pod. NetworkPolicy generation available via CLI.

â€œPer-pod remediation recommendations generated with each scan

â€œNetworkPolicy auto-generation: reflex generate netpol

â€œAlert-based notification for security regressions

â€œManual incident response process not verified by Reflex

Remediation

Document incident response procedures. Configure alerting destinations (Slack, PagerDuty) for automated notification.

CC8.1 – Change Management and Vulnerability Remediation

Status: **FAIL** Score: 0/100 Violations: 1042

Evidence

Critical CVEs: 1042 (17 fixable). High CVEs: 11696. Total across 10 pods.

- Critical CVEs: 1042 (17 fixable)
- High CVEs: 11696
- Top affected pods: order-service (2941), analytics-engine (2845), notification-service (2484)
- Vulnerability data sourced from Trivy with NVD/GHSA databases

Findings (10)

- **CRITICAL:** 1042 critical CVEs detected (17 fixable)
- **HIGH:** 11696 high-severity CVEs exceed threshold
 - analytics-engine: 268C/2577H CVEs (image: python:3.8.12)
 - notification-service: 226C/2258H CVEs (image: node:18.12.0)
 - cart-service: 12C/100H CVEs (image: redis:6.2.7)
 - api-gateway: 26C/137H CVEs (image: nginx:1.21.6)
 - order-service: 283C/2658H CVEs (image: python:3.9.7)
 - user-service: 66C/988H CVEs (image: node:16.14.0)
 - auth-service: 107C/1651H CVEs (image: golang:1.19.5)
 - inventory-service: 54C/1285H CVEs (image: golang:1.21.5)

Remediation

Patch all critical CVEs immediately. Prioritize fixable CVEs. Update base images to latest stable versions.

CC9.1 Risk Mitigation

Status: **PARTIAL** Score: 50/100 Violations: 0

Evidence

Automated risk scoring and remediation guidance. NetworkPolicy generation available. 9 pods with remediation recommendations.

- Pods with remediation recommendations: 9/10
- NetworkPolicy auto-generation: reflex generate netpol
- Risk-ranked pod list enables prioritized remediation

Remediation

Address critical-tier pods first. Apply generated NetworkPolicies. Patch fixable CVEs.

C1.1 “ Confidential Information Protection

Status: FAIL Score: 0/100 Violations: 5

Evidence

Plaintext secrets in env vars: 5 pods. RBAC secret access: 0 pods.

Pod with plaintext secrets in env: analytics-engine, notification-service, cart-service, auth-service, payment-service

Pod with RBAC secret read access: none

Findings (5)

- CRITICAL: analytics-engine has plaintext secrets in environment variables
- CRITICAL: notification-service has plaintext secrets in environment variables
- CRITICAL: cart-service has plaintext secrets in environment variables
- CRITICAL: auth-service has plaintext secrets in environment variables
- CRITICAL: payment-service has plaintext secrets in environment variables

Remediation

Move all secrets to Kubernetes Secrets or a vault. Restrict secret RBAC access to pods that need it.

A1.1 “ System Availability and Recovery

Status: **PARTIAL** Score: 80/100 Violations: 0

Evidence

Workload monitoring active for 10 pods. Recovery mechanisms not fully verified.

- Continuous monitoring: 10 pods
- Blast radius analysis identifies single-points-of-failure
- Kubernetes self-healing (restarts, replicas) assumed but not verified

Remediation

Ensure all critical workloads have replicas > 1. Configure PodDisruptionBudgets.

Top 5 Highest Blast Radius Pods

#	Pod	Score	Tier	CVEs (C/H)	Blast	Image
1	search-service	90	critical	0C/33H	10 svc+inet	elasticsearch:7.17.7
2	analytics-engine	87	critical	268C/2577H	10 svc+inet	python:3.8.12
3	notification-service	82	critical	226C/2258H	10 svc+inet	node:18.12.0
4	cart-service	80	critical	12C/100H	10 svc+inet	redis:6.2.7
5	api-gateway	79	critical	26C/137H	10 svc+inet	nginx:1.21.6

#1 search-service “ Score: 90/100 (critical)

Image: elasticsearch:7.17.7
CVEs: 0 critical, 33 high, 226 medium (259 total, 258 fixable)
Blast radius: 10 reachable services | Internet: true | NetworkPolicy: false
Privileged: true | Root: true | Read-only FS: false
[critical] Add a NetworkPolicy
[high] Run as non-root
[critical] Remove privileged mode

#2 analytics-engine “ Score: 87/100 (critical)

Image: python:3.8.12
CVEs: 268 critical, 2577 high, 5666 medium (8511 total, 6714 fixable)
Blast radius: 10 reachable services | Internet: true | NetworkPolicy: false
Privileged: false | Root: true | Read-only FS: false
[critical] Add a NetworkPolicy
[high] Update base image
[high] Run as non-root

#3 notification-service “ Score: 82/100 (critical)

Image: node:18.12.0
CVEs: 226 critical, 2258 high, 4831 medium (7315 total, 5529 fixable)
Blast radius: 10 reachable services | Internet: true | NetworkPolicy: false
Privileged: false | Root: false | Read-only FS: false
[critical] Add a NetworkPolicy
[high] Update base image

#4 cart-service “ Score: 80/100 (critical)

Image: redis:6.2.7
CVEs: 12 critical, 100 high, 139 medium (251 total, 220 fixable)
Blast radius: 10 reachable services | Internet: true | NetworkPolicy: false
Privileged: false | Root: false | Read-only FS: false
[critical] Add a NetworkPolicy
[high] Update base image

#5 api-gateway “ Score: 79/100 (critical)

Image: nginx:1.21.6
CVEs: 26 critical, 137 high, 226 medium (389 total, 328 fixable)
Blast radius: 10 reachable services | Internet: true | NetworkPolicy: false
Privileged: false | Root: false | Read-only FS: false
[critical] Add a NetworkPolicy
[high] Update base image